

**SIMATS ENGINEERING
ASSESSMENT TOOL 3**

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1436

COURSE OUTCOME COVERED

***CO1:** Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.*

QUESTIONS: 01

Total Marks:100

Annexure A

ASSIGNMENT

Code of Conduct:

I Pusalapati Chandu / 192372119 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Pchandu

S.No.	Assessment Criterion	Excellent - 4	Good -3	Satisfactory -2	Needs Improvement -1	Marks
1	Understanding of the Scenario - 10	Clearly identifies all stakeholders, actions, risks, and security concerns presented in the scenario.	Identifies most major elements with minor omissions.	Identifies only the basic elements of the scenario.	Misinterprets the scenario or misses important issues.	
2	Application of Ethical Hacking Principles -20	Accurately applies authorization, scope, privacy, confidentiality, integrity, and professional responsibility.	Applies most ethical hacking principles correctly.	Demonstrates basic understanding but provides limited application.	Ethical principles are incorrectly applied or not discussed.	
3	Legal and Ethical Analysis - 30	Clearly distinguishes legal, illegal, ethical, and unethical actions with strong justification.	Identifies most legal and ethical issues with reasonable explanation.	Provides a general discussion with limited justification.	Legal and ethical issues are unclear, inaccurate, or missing.	
4	Recommended Course of Action -20	Proposes a practical, responsible, legally appropriate, and well-justified solution.	Proposes an appropriate solution with minor gaps.	Provides a basic solution with limited explanation.	Suggests an inappropriate, unsafe, or unsupported action.	
5	Critical Thinking and Presentation-20	Response is logical, original, well-organized, professionally written, and supported with suitable examples.	Response is clear and organized with minor weaknesses.	Response is understandable but lacks depth or examples.	Response is unclear, poorly organized, or unsupported.	
					Total	

ASSIGNMENT QUESTION

27. Recording Employee Passwords

During an authorized social-engineering assessment, a tester successfully obtains several employee passwords and stores them in an unencrypted document.

Identify the ethical and security failures. Recommend appropriate data-handling and reporting procedures.

1. Introduction

Social engineering is a security-testing technique in which an authorized tester evaluates whether employees can be manipulated into revealing sensitive information such as passwords. In this scenario, the social-engineering assessment itself is authorized, so obtaining passwords may be within the agreed testing activity if the rules of engagement specifically permit it. However, the tester commits a serious security and ethical failure by storing the real employee passwords in an unencrypted document.

The main problem is therefore not simply obtaining the credentials during an authorized test, but the unsafe collection, storage, handling, and possible exposure of highly sensitive authentication information.

KEY PRINCIPLE:

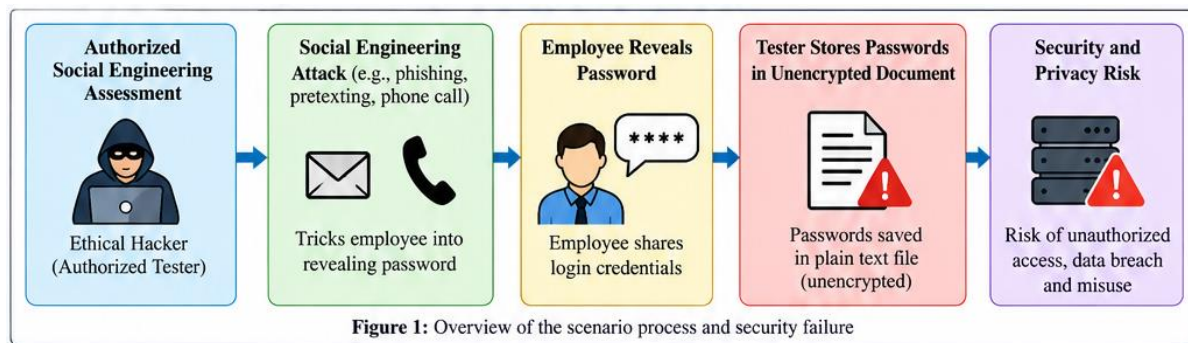
Authorization to perform a security test does not give unlimited permission to handle sensitive information carelessly.

2. Understanding the Scenario

The major stakeholders are the security tester, employees whose passwords were obtained, the organization/client, the IT or security team, and management or legal/data-protection personnel.

- Security tester – conducts the authorized social-engineering assessment and is responsible for protecting collected evidence.
- Employees – their passwords have been captured and they may face account compromise if the credentials are exposed.
- Organization/client – authorized the assessment and is responsible for protecting organizational and employee information.
- IT/Security team – investigates the finding, manages credential resets, and improves security controls.
- Management/Legal team – assesses contractual, policy, privacy, and compliance implications where necessary.

3. Scenario Flow Diagram



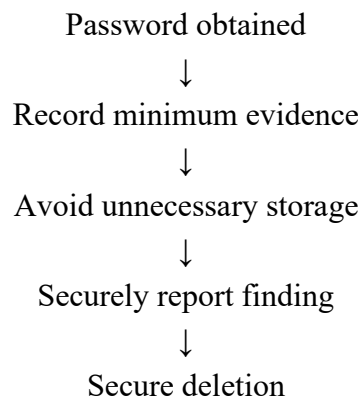
4. Ethical Failures

4.1 Failure to Protect Confidential Information

Employee passwords are highly sensitive authentication credentials. The tester has a professional responsibility to protect information obtained during the assessment. Storing passwords in an unencrypted document means that anyone who gains access to the document may be able to read the credentials. This violates the principle of confidentiality.

4.2 Excessive Collection of Sensitive Data

The tester should follow data minimization. If the purpose of the assessment is to demonstrate that employees can be persuaded to reveal passwords, there is generally no need to retain a large collection of real passwords longer than necessary.



4.3 Lack of Secure Handling

The document containing passwords is unencrypted. This creates risks such as unauthorized access, accidental disclosure, credential theft, internal misuse, account compromise, employee privacy loss, and reputational damage.

4.4 Violation of Professional Responsibility

An ethical hacker is expected to behave responsibly even when the organization has authorized the assessment. Authorization permits the agreed security activity; it does not permit careless storage or unnecessary exposure of sensitive information.

5. Security Failures

Failure	Risk
Passwords stored in plaintext	Anyone accessing the file can read them.
No encryption	Credentials are not adequately protected.
Multiple passwords collected	Impact increases if the file is exposed.
Sensitive data retained unnecessarily	Longer exposure period.
Possible uncontrolled access	Unauthorized persons may obtain credentials.
Poor evidence handling	Confidentiality and integrity may be compromised.
Lack of secure deletion	Passwords may remain available after testing.

6. Application of Ethical Hacking Principles

The key ethical-hacking principles relevant to this scenario are authorization, scope, privacy, confidentiality, integrity, data minimization, and professional responsibility.

6.1 Authorization

The scenario states that the social-engineering assessment is authorized. Therefore, the tester may perform activities explicitly included in the authorization. However, authorization should be checked carefully to determine whether collecting and retaining real passwords was specifically permitted.

Authorized social engineering
≠
Unlimited permission to collect or store passwords

6.2 Scope

The tester must remain within the agreed testing scope. The scope should identify the targets, approved methods, evidence requirements, time period, and restrictions on sensitive information.

TESTING SCOPE
↓
Targets + Methods + Evidence Handling
↓
Only approved activities

6.3 Privacy

Employee passwords are private and sensitive information. The tester should collect only the information necessary to prove the security weakness. A safer evidence record would identify the test result while redacting or not retaining the actual password.

Employee ID: EMP-01
Result: Password successfully disclosed
Actual Password: NOT RETAINED

Finding: Credential disclosure

6.4 Confidentiality

Confidentiality requires preventing sensitive information from being disclosed to unauthorized people. The tester should use approved secure storage, encryption, restricted permissions, and controlled access. Passwords should not be sent through ordinary email, public storage, or messaging applications.

6.5 Integrity

Evidence collected during a security assessment should remain accurate and trustworthy. The tester should not alter evidence to exaggerate findings, mix evidence with unrelated information, or allow unauthorized modification.

6.6 Professional Responsibility

The tester has a duty to minimize harm. A professional ethical hacker should ask: How can I prove the vulnerability while exposing the minimum amount of sensitive information?

7. Legal and Ethical Analysis

The authorized nature of the assessment does not make every subsequent action automatically acceptable. The tester must distinguish authorized testing from improper handling of the resulting credentials.

Action	Assessment
Authorized social-engineering test	Potentially legal and ethical when properly authorized.
Obtaining credentials within approved scope	Potentially acceptable if explicitly authorized and necessary.
Storing passwords in plaintext	Unethical and insecure.
Giving passwords to unauthorized people	Unethical and potentially unlawful.
Using employee passwords to access real accounts	Unauthorized and potentially unlawful unless separately authorized.
Publishing employee passwords	Seriously unethical and potentially unlawful.
Keeping credentials without justification	Poor professional practice.

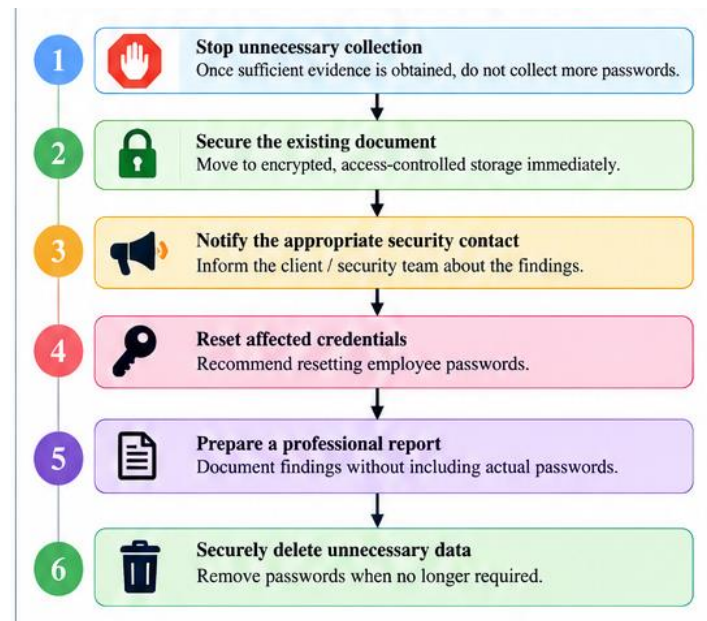
The exact legal consequences depend on applicable law, contractual terms, organizational policy, and what the tester actually does with the credentials. The safest professional approach is to minimize collection, protect the information, report the issue, and securely dispose of unnecessary credentials.

8. Recommended Data-Handling Procedure

1. Stop unnecessary collection – once sufficient evidence has been obtained, do not collect additional real passwords.
2. Secure the existing document – move evidence into organization-approved secure storage with encryption and restricted access.
3. Notify the appropriate security contact – report the credential-handling issue through the approved channel.

4. Protect affected accounts – recommend password resets and review relevant authentication activity where appropriate.
5. Document the finding – record the test method, result, impact, and remediation without reproducing actual passwords.
6. Securely delete unnecessary password data – follow the organization's approved retention and evidence-destruction procedure.

9. Recommended Procedure Flowchart



10. What the Tester Should NOT Do

- Do not store passwords in plaintext.
- Do not email passwords to personal accounts.
- Do not upload passwords to public or personal cloud storage.
- Do not share passwords through messaging applications.
- Do not include actual passwords in the final report.
- Do not use obtained passwords to access other systems without explicit authorization.
- Do not keep credentials indefinitely.
- Do not publish credentials as proof.

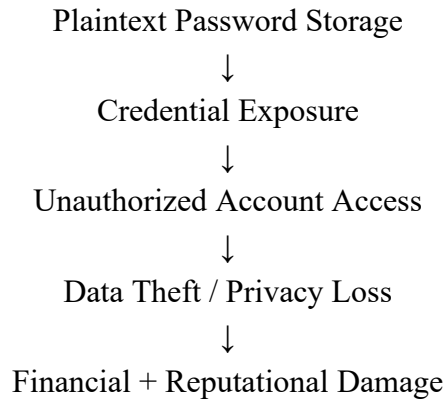
11. Safer Evidence Example

Test ID: SE-027
Target: Authorized Employee
Attack Type: Social Engineering
Result: SUCCESS
Credential: Password obtained
Actual Value: REDACTED
Impact: Unauthorized credential disclosure

Recommendation: Security awareness + MFA + password policy

12. Risk Assessment

The overall risk can be considered using the relationship $\text{Risk} = \text{Likelihood} \times \text{Impact}$. Password exposure can have high impact because exposed credentials may enable unauthorized access, particularly where passwords are reused. The tester should therefore treat insecure credential storage as a high-priority finding, subject to the organization's actual risk assessment.



How the Tester Should NOT Handle the Passwords

The following practices should be avoided:

- ❖ Store passwords in plain text
- ❖ Email passwords to personal accounts
- ❖ Upload passwords to public cloud storage
- ❖ Share passwords through WhatsApp/chat
- ❖ Include actual passwords in the final report
- ❖ Use obtained passwords to access other systems
- ❖ Keep credentials indefinitely
- ❖ Share credentials with unauthorized employees
- ❖ Publish credentials as proof

13. Ethical vs. Unethical Actions

Ethical / Responsible	Unethical / Unsafe
Obtain credentials only within approved scope	Obtain credentials outside scope
Collect minimum evidence	Collect unnecessary passwords
Protect evidence using approved controls	Store passwords in plaintext
Report findings confidentially	Publish credentials
Reset/remediate affected accounts	Use credentials for personal access
Delete unnecessary sensitive data	Retain passwords indefinitely
Follow rules of engagement	Ignore engagement rules

14. Justification

The tester's actions must be evaluated in two stages. First, the social-engineering activity was authorized, so credential disclosure may be a valid test result if it was explicitly included in the rules of engagement. Second, storing the obtained passwords in an unencrypted document is not a safe or professionally responsible way to handle sensitive evidence.

This conclusion is justified because ethical hacking requires more than technical skill. The tester must preserve confidentiality, respect privacy, remain within scope, minimize potential harm, maintain evidence integrity, and act professionally. The vulnerability can be demonstrated without retaining the actual passwords.

Therefore, the correct response is to secure the existing evidence, restrict access, notify the responsible security contact, recommend remediation for affected accounts, document the finding without exposing passwords, and securely delete unnecessary credential information.

15. Final Recommendation

- Confirm that credential collection was within the authorized scope.
- Stop collecting additional credentials once sufficient evidence exists.
- Move sensitive evidence to approved encrypted storage.
- Restrict evidence access to authorized personnel only.
- Never use the obtained passwords for unauthorized access.
- Inform the client/security team through the approved reporting channel.
- Recommend resetting affected employee passwords where appropriate.
- Review whether the credentials were exposed or misused.
- Do not place actual passwords in the final report.
- Securely delete unnecessary credential information according to the engagement's retention policy.

16. Conclusion

In conclusion, the tester's main failure is not necessarily the authorized collection of credentials, but the unsafe storage and handling of those credentials. Employee passwords are highly sensitive information and must be protected throughout the penetration-testing lifecycle.

A responsible ethical hacker should follow authorization, scope, privacy, confidentiality, integrity, data minimization, and professional responsibility. The passwords should be securely protected, the appropriate security team should be informed, affected accounts should be considered for password reset, and unnecessary credential information should be securely deleted.

CORE CONCLUSION

Collect only what is necessary → Protect it securely → Report it responsibly → Delete it when it is no longer required.